Segmentazione e Mitigazione di Vulnerabilità tramite pfSense

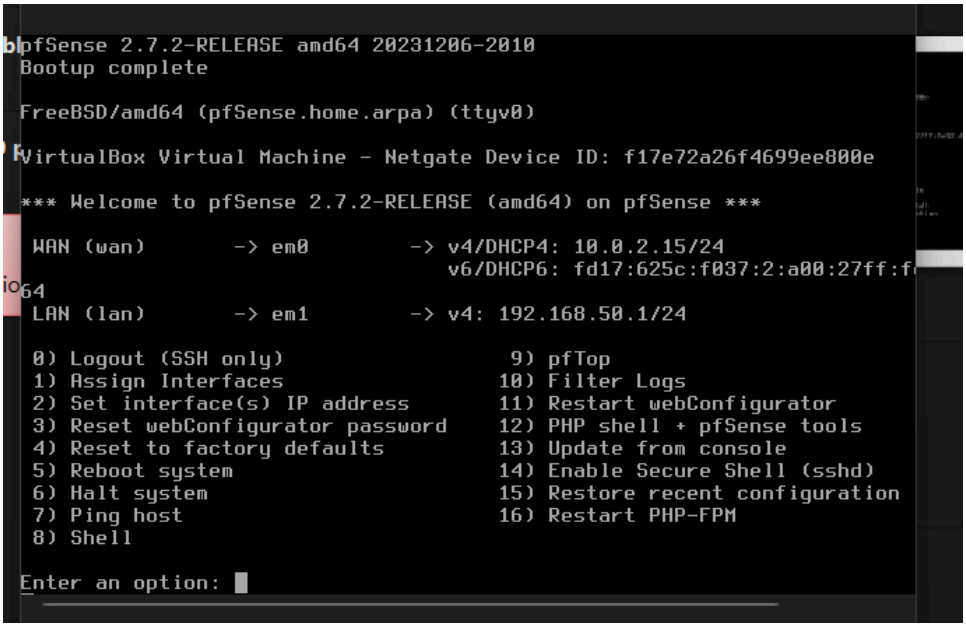
1. Introduzione e Obiettivo

L'obiettivo primario di questa attività di laboratorio è la messa in sicurezza di una macchina vulnerabile vulnerabile (Metasploitable 2) all'interno di un'infrastruttura di rete controllata. Il progetto si focalizza sulla riduzione della superficie di attacco mediante la segmentazione della rete e l'implementazione di politiche di filtraggio granulari (ACL) utilizzando il firewall perimetrale pfSense.

2. Architettura di Rete Dettagliata

La topologia di rete implementata prevede la separazione del traffico in diverse zone di sicurezza:

- **Firewall (Gateway):** pfSense, configurato come centro stella per il routing tra le sottoreti. L'IP dell'interfaccia dedicata alla vittima è ***192.168.2.1.***
- **Zona LAN (Admin/Attaccante):** Ospita l'host Kali Linux con indirizzo IP ***192.168.50.100.***
- **Zona DMZ/Vittima (Quarantena):** Isola l'host Metasploitable 2 con indirizzo **IP statico** ***192.168.2.10.***



3. Procedura Operativa e Configurazione

La configurazione è stata eseguita seguendo un approccio metodologico a fasi:

Fase A: Configurazione dell'Interfaccia di Rete

1. In pfSense, è stata abilitata l'interfaccia fisica corrispondente alla scheda di rete della vittima, rinominandola come: ***METASPLOITABLE (OPT1).***
2. È stato assegnato un indirizzamento IPv4 statico ***(192.168.2.1/24)*** per definire il gateway della nuova sottorete.

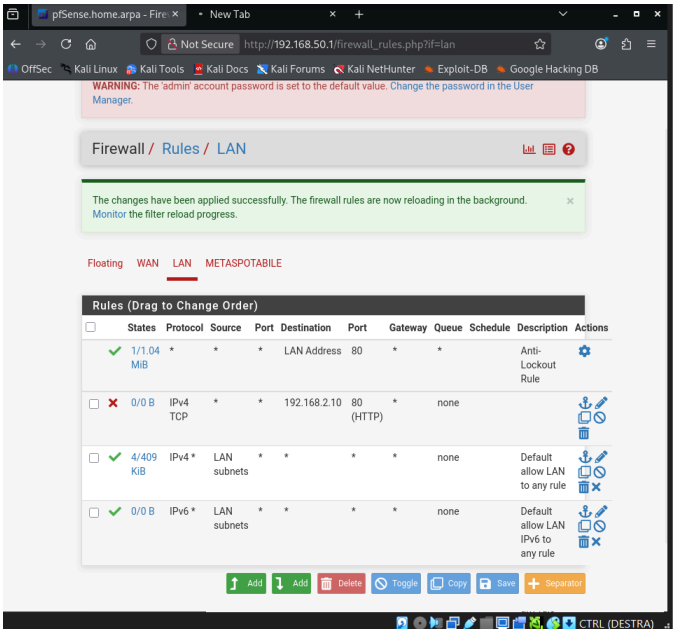
Fase B: Provisioning dell'Host Vittima

Per garantire che la macchina vulnerabile comunichi esclusivamente attraverso il firewall, è stata configurata manualmente la rete a livello di sistema operativo:

- **Assegnazione IP:** sudo ifconfig eth0 ***192.168.2.10*** netmask ***255.255.255.0.***
- **Configurazione Instradamento:** sudo route add default gw ***192.168.2.1.***

Fase C: Implementazione delle Regole di Sicurezza (Firewall Rules)

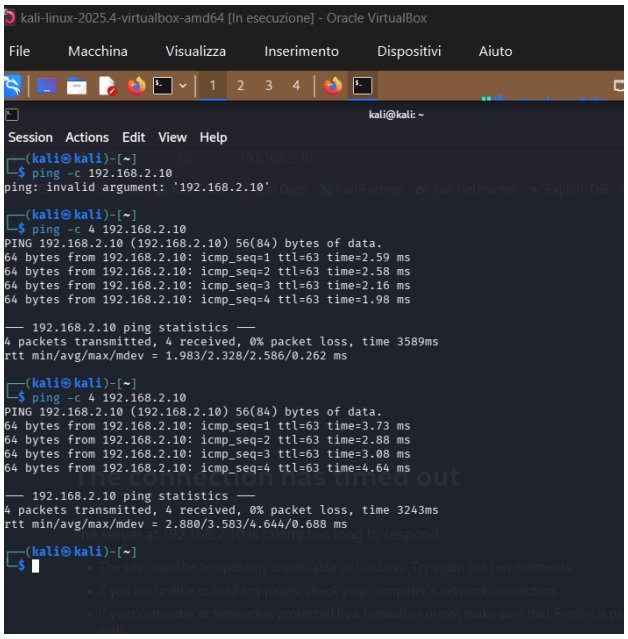
Per inibire lo sfruttamento delle vulnerabilità web note della Metasploitable, è stata creata una regola di tipo Block sull'interfaccia LAN. I dettagli tecnici della regola sono:

- **Azione:** Block (Scarto immediato del pacchetto senza risposta all'origine).
- **Protocollo:** TCP (utilizzato dal servizio HTTP).
- **Source:** LAN net (o l'IP specifico 192.168.50.100).
- **Destination**: 192.168.2.10.
- **Destination Port Range:** HTTP (80).
- **Logging:** Abilitato per la tracciabilità degli incidenti.
- **Priorità:** La regola è stata posizionata in "Top of the list" per scavalcare eventuali regole di "Pass" preesistenti.
- 

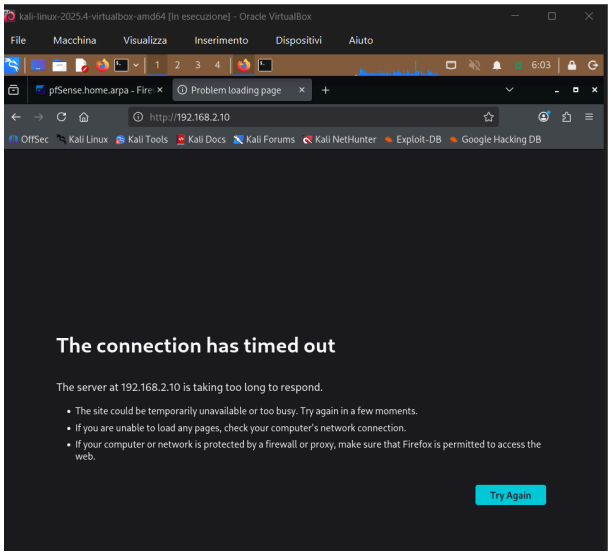
4. Test di Verifica e Analisi dei Risultati

La validazione della configurazione è stata effettuata tramite test incrociati:

1. **Test di Raggiungibilità (Layer 3):** Eseguendo un ping dall'host Kali verso ***192.168.2.10***, si è ottenuto il 0% di pacchetti persi. Questo dimostra che il routing tra le zone è attivo e che il firewall permette il traffico ICMP di diagnostica.



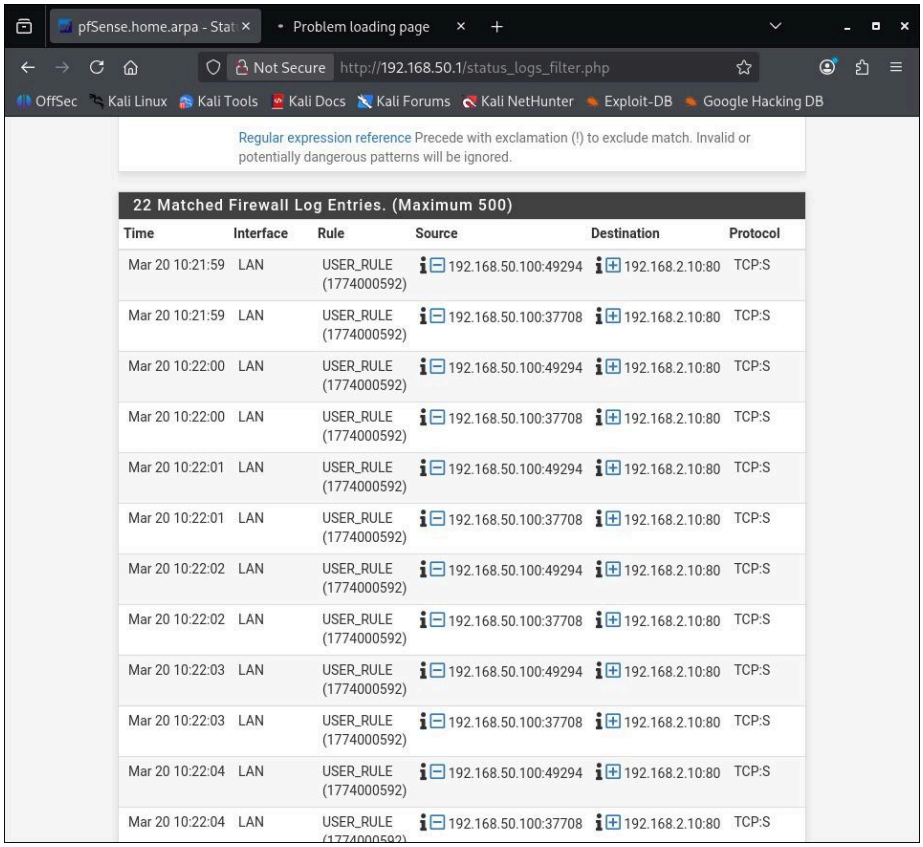
2. **Test di Sicurezza Applicativa (Layer 7):** Il tentativo di accesso tramite browser web ha prodotto un errore di "Connection timed out". Questo risultato è fondamentale: indica che il firewall sta silenziosamente scartando i pacchetti diretti alla porta 80, impedendo l'accesso ai servizi vulnerabili.



5. Monitoraggio e Analisi dei Log in Tempo Reale

L'analisi dei System Logs di pfSense ha confermato visivamente l'efficacia della regola.

- Nei log si osserva l'attivazione della USER_RULE (la regola creata manualmente).
- Ogni tentativo di connessione dall'IP ***192.168.50.100 verso 192.168.2.10:80*** viene marcato con un'icona rossa, a indicare il blocco riuscito.



Time	Interface	Rule	Source	Destination	Protocol
Mar 20 10:21:59	LAN	USER_RULE (1774000592)	192.168.50.100:49294	192.168.2.10:80	TCP:S
Mar 20 10:21:59	LAN	USER_RULE (1774000592)	192.168.50.100:37708	192.168.2.10:80	TCP:S
Mar 20 10:22:00	LAN	USER_RULE (1774000592)	192.168.50.100:49294	192.168.2.10:80	TCP:S
Mar 20 10:22:00	LAN	USER_RULE (1774000592)	192.168.50.100:37708	192.168.2.10:80	TCP:S
Mar 20 10:22:01	LAN	USER_RULE (1774000592)	192.168.50.100:49294	192.168.2.10:80	TCP:S
Mar 20 10:22:01	LAN	USER_RULE (1774000592)	192.168.50.100:37708	192.168.2.10:80	TCP:S
Mar 20 10:22:02	LAN	USER_RULE (1774000592)	192.168.50.100:49294	192.168.2.10:80	TCP:S
Mar 20 10:22:02	LAN	USER_RULE (1774000592)	192.168.50.100:37708	192.168.2.10:80	TCP:S
Mar 20 10:22:03	LAN	USER_RULE (1774000592)	192.168.50.100:49294	192.168.2.10:80	TCP:S
Mar 20 10:22:03	LAN	USER_RULE (1774000592)	192.168.50.100:37708	192.168.2.10:80	TCP:S
Mar 20 10:22:04	LAN	USER_RULE (1774000592)	192.168.50.100:49294	192.168.2.10:80	TCP:S
Mar 20 10:22:04	LAN	USER_RULE	192.168.50.100:37708	192.168.2.10:80	TCP:S

6. Conclusione

Il laboratorio ha dimostrato con successo come una corretta segmentazione e l'uso di regole ACL specifiche possano proteggere host vulnerabili all'interno di una rete aziendale. Nonostante la vulnerabilità intrinseca dell'host vittima, la protezione perimetrale fornita da pfSense neutralizza efficacemente i vettori d'attacco basati su HTTP.